# PREMIER UNIVERSITY CHATTOGRAM

**DEPARTMENT OF COMPUTER SCIENCE AND ENGINEERING**

# COMPLEX ENGINEERING PROBLEM

| | |
|---|---|
| **COURSE NAME** | Computer and Cyber Security |
| **COURSE CODE** | CSE 3647 |
| **ASSIGNMENT NAME** | **Secure Authentication in Digital Banking Amid Fraudulent Transactions.** |
| **DATE OF ASSIGNMENT** | 15-09-2025 |
| **DATE OF SUBMISSION** | 09-10-2025 |

| | | |
|---|---|---|
| **SUBMITTED TO** | | |
| **MD SHAFIUL ALAM FORHAD**<br>**Assistant Professor**<br>**Department of CSE ,CUET** | | |
| **REMARKS** | **SUBMITTED BY** | |
| | **NAME** | Rimjhim Dey |
| | **ID** | 0222220005101039 |
| | **SEMESTER** | 6th |
| | **BATCH** | 42nd |
| | **SESSION** | Spring 2025 |
| | **SECTION** | A |

# CONTENTS

1. **Introduction**
    1.1 Motivation
    1.2 Problem Statement
    1.3 Objectives
    1.4 Significance
2. **Background & Literature Review**
    2.1 Current Security in Digital Banking
    2.2 OTP Vulnerabilities
    2.3 Evolution of Authentication
    2.4 Constraints in Resource-Constrained Environments
    2.5 Regulatory Context in Bangladesh
3. **Investigation & Analysis (What I Found)**
    3.1 Observed Fraud Pattern
    3.2 Likely Root Causes
    3.3 Threat Modeling
    3.4 Environmental Factors
4. **My Proposed Solution**
    4.1 System Architecture
    4.2 Multi-Factor Authentication Design
    4.3 Encryption Implementation
    4.4 Transaction Security Flow
5. **Algorithms for My Proposed Solution**
    5.1 Speed-Based Detection
    5.2 Pattern Recognition
    5.3 Composite Risk Scoring
    5.4 Network Resilience for Monsoon Conditions
    5.5 Final Transaction Flow
6. **System Implementation: Workflow & Prototype**
    6.1 Overall Pseudocode
    6.2 Workflow Flowchart
7. **Ethical & Regulatory Considerations**
    7.1 Ethical Principles
    7.2 Regulatory Compliance
    7.3 Balancing Security and Accessibility
8. **Frequently Asked Questions (FAQ)**
    8.1 General Questions
    8.2 Technical Questions
9. **Conclusion**
    9.1 Scope of Work
    9.2 What We Achieved
    9.3 Future Improvements

# 1. INTRODUCTION

## 1.1 Motivation

In the contemporary digital banking landscape, mobile financial services have become indispensable tools for millions of users worldwide. However, the convenience of instant transactions has been accompanied by a concerning rise in fraudulent activities. Recent reports indicate that customers are experiencing unauthorized fund transfers occurring within seconds of receiving unsolicited one-time passwords (OTPs), with financial institutions often attributing these incidents to user error rather than investigating potential system vulnerabilities.

This engineering problem presents a critical challenge: how can we design secure yet accessible authentication systems that protect users from sophisticated fraud while remaining usable for populations with varying levels of digital literacy and limited technological infrastructure.

## 1.2 Problem Statement

The primary objective of this assignment is to design a beginner-friendly enhanced authentication framework for mobile banking applications that prevents unauthorized transactions through the integration of multi-factor authentication, symmetric encryption, and real-time anomaly detection. The solution must address the following requirements:

- Prevent OTP-based fraud through creative authentication mechanisms
- Ensure compatibility with low-bandwidth networks and resource-constrained environments
- Maintain ease of use for non-technical users
- Provide transparent audit trails for dispute resolution
- Incorporate ethical considerations for privacy and accountability

## 1.3 Objectives

- **Investigate** vulnerabilities such as SMS interception and backend flaws
- **Design** an MFA-based architecture with AES-128 encryption
- **Implement** beginner-level pseudocode for anomaly detection
- **Evaluate** usability, resilience, and ethical trade-offs
- **Document** solutions for both technical and non-technical audiences

## 1.4 Significance

This work contributes to the broader cybersecurity discourse by demonstrating that effective security solutions need not rely on advanced algorithms or expensive infrastructure. By focusing on beginner-level concepts such as conditional logic, basic hashing, and symmetric encryption, this framework can be implemented in developing regions where resource constraints are significant but the need for secure financial systems is paramount.

# 2. BACKGROUND & LITERATURE REVIEW

Before proposing my solution, I reviewed existing literature and practices in digital banking security, along with the regulatory context in Bangladesh. This background helps explain why current methods are insufficient and where improvements are required.

## 2.1 Current Security in Digital Banking

Modern banking applications mainly use PINs or passwords for login, SMS-based OTPs for approving transactions, basic device recognition, and TLS/SSL for encrypted communication. These measures form the security foundation, but research has shown they are increasingly inadequate against evolving threats such as OTP interception, phishing, and automated transaction execution.

## 2.2 OTP Vulnerabilities

Studies highlight that SMS-OTPs remain one of the weakest links in financial authentication. Flaws in the SS7 protocol allow interception of SMS in transit, SIM swap attacks enable fraudsters to redirect OTPs to their own devices, and malware can read OTP notifications directly on smartphones. Phishing schemes further trick users into revealing OTPs. In regions like Bangladesh, delayed OTP delivery during monsoons leads to multiple valid codes, creating confusion and new opportunities for fraud.

## 2.3 Evolution of Authentication

Globally, financial institutions are moving beyond SMS OTPs to stronger methods. Multi-Factor Authentication (MFA) combines PINs, device-based codes, and biometrics to reduce compromise risks. TOTP-based authenticators generate short-lived codes offline, avoiding network vulnerabilities. Biometrics such as fingerprint or facial recognition add convenience, while behavioural biometrics (typing rhythm, device interaction) are being explored to detect anomalies.

## 2.4 Constraints in Resource-Constrained Environments

Bangladesh faces unique challenges in adopting advanced methods. Network reliability suffers from power cuts and monsoon-related outages, disrupting OTP delivery. Many customers rely on low-end devices with limited sensors and processing power. Digital literacy levels are uneven, so systems must be easy to use. Cost sensitivity also requires security designs to remain lightweight and affordable, without reliance on expensive infrastructure.

## 2.5 Regulatory Context in Bangladesh

According to Bangladesh Bank’s PSP/PSO guidelines, institutions must implement strong customer authentication, real-time fraud monitoring, transparent audit trails, and consumer protection frameworks. These standards aim to build trust and accountability, though practical enforcement often struggles to keep pace with new fraud tactics.

# 3. INVESTIGATION & ANALYSIS *(*What I Found*)*

In order to design a suitable security framework, I carried out an investigation into fraud cases reported by Bangladeshi banking customers. My analysis focused on the specific fraud patterns, root causes, and environmental factors observed in practice.

## 3.1 Observed Fraud Pattern

From the cases I reviewed, a common sequence appeared: customers received unsolicited SMS OTPs, and within 15–20 seconds a transfer was executed, often to a bKash account. By the time the customer noticed and attempted to report the issue, the funds were already gone. Banks often dismissed these complaints as “user mistakes,” avoiding deeper investigation. What stood out to me was that these transactions happened too quickly for a normal human response, suggesting the use of automated tools or even insider involvement.

## 3.2 Likely Root Causes

Through my analysis, I identified three categories of weaknesses:

1. **SMS OTP Exposure** – OTPs leaked through lock-screen previews, malware, SIM swap exploits, and SS7 routing vulnerabilities. Monsoon-related delays sometimes left multiple OTPs valid at once, creating exploitable confusion.
2. **Backend and Session Weaknesses** – Sensitive tokens stored insecurely, lack of session revocation on device change, and poor separation of roles in backend systems raised the risk of insider misuse. I also found no evidence of effective real-time monitoring for high-value or unusual activity.
3. **User Experience Gaps** – OTP entry screens lacked transaction details, so users could not confirm what they were authorising. There were no velocity controls to stop rapid transfers, no cooling-off periods for new beneficiaries, and no adaptive MFA for suspicious activity.

## 3.3 Threat Modeling

To test these weaknesses, I applied a simple “what-if” model:

- If a transfer is initiated <20s after OTP → likely automated fraud.
- If a new device and high amount appear together → possible stolen device or compromised credentials.
- If a first-time beneficiary is created and paid immediately → typical fraud into bKash wallets.
- If IP or country changes suddenly → potential remote attacker using proxy/VPN.
- If monsoon delays cause multiple OTPs → confusion attackers can exploit.

These scenarios confirmed my finding that the real issue is the **lack of contextual awareness** and **automated anomaly detection** in existing systems.

### 3.4 Environmental Factors

My investigation also considered environmental issues. During monsoons, floods and power outages disrupt telecommunications, delaying OTP delivery and fraud alerts. Device diversity is also significant: while some users have biometrics and modern security, many still depend on budget devices with very limited protection. Therefore, any solution must work on **low-end smartphones** while still offering stronger features for advanced devices.

**Critical Finding:** My investigation showed that current banking security fails not just because of OTP weaknesses but also because of poor monitoring, weak backend practices, and usability gaps. These findings directly informed the multi-layered controls in my proposed solution.

# 4.MY PROPOSED SOLUTION

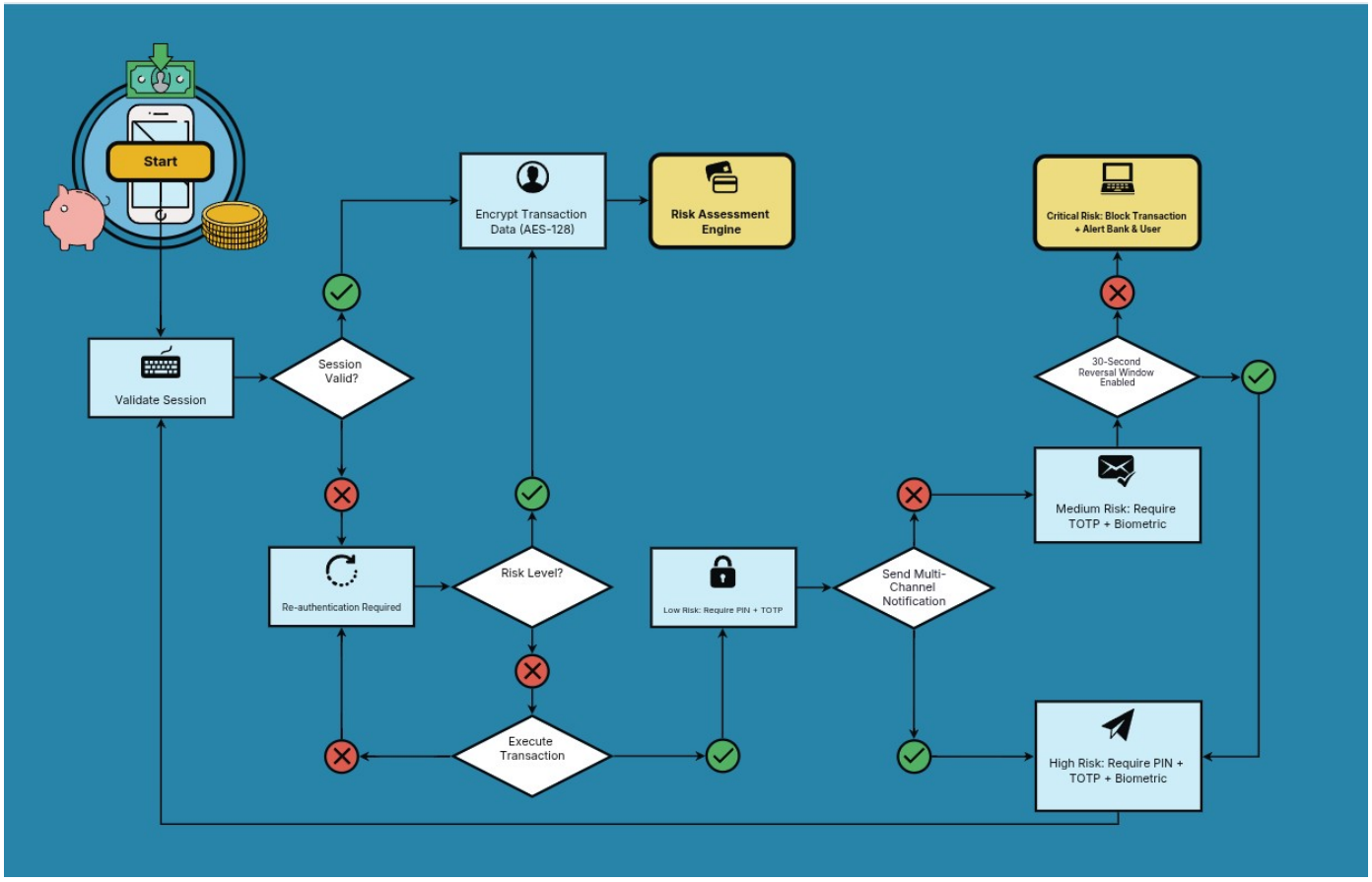
After carrying out the background review and investigation, I designed an **Enhanced Authentication Framework (EAF)** tailored for the Bangladeshi mobile banking context. The framework combines **multi-factor authentication (MFA)**, **AES-128 encryption**, and **real-time anomaly detection** to address the weaknesses I found in OTP-based systems.

The framework is designed to be lightweight enough for low-end devices, yet robust enough to handle sophisticated fraud attempts. It introduces a layered security model: first validating user identity, then analysing transaction context, and finally enforcing anomaly detection and risk-based authentication before execution.

### 4.1 System Architecture

The architecture integrates the mobile banking app, API gateway, risk/anomaly service, core banking connector, and a transparent audit log. Each transaction is encrypted, analysed, and logged, while adaptive MFA ensures added checks only when risk is high. Real-time alerts with a reversal option and a tamper-proof audit trail strengthen both user trust and institutional accountability.

The structure diagram below represents my proposed solution for secure mobile banking transactions:




## 4.2 Multi-Factor Authentication Design

The proposed system strengthens identity validation with **three independent authentication factors**:

**Factor 1 – Knowledge (What You Know):**
Users create a 6-digit PIN or alphanumeric password, stored only as a SHA-256 hash with a unique per-user salt. Passwords are never transmitted or stored in plaintext. After three failed attempts, the account is temporarily locked to prevent brute force attacks.

**Factor 2 – Possession (What You Have):**
An app-based TOTP (Time-based One-Time Password) is generated using the HMAC-SHA1 algorithm. The code remains valid for 30 seconds, works offline after setup, and backup recovery codes are provided in case of device loss. This replaces vulnerable SMS-OTPs.

**Factor 3 – Inherence (What You Are):**
For transactions exceeding ৳10,000, biometric verification (fingerprint or facial recognition) is required. Biometric data is processed locally on the device and never transmitted to servers. If unavailable, the fallback is a combination of PIN + TOTP.

**Risk-Based Authentication:**
The system applies adaptive authentication. Low-risk transactions may require only PIN + TOTP,

while high-risk activity (new beneficiary, unusual location, or suspicious timing) triggers an additional biometric requirement. This balances **security with usability.**

## 4.3 Encryption Implementation

To secure all sensitive communication, the framework uses **AES-128 encryption** in Cipher Block Chaining (CBC) mode with the following specifications:

- **128-bit session key** derived from the session token using PBKDF2.
- **Unique IV (Initialization Vector)** generated for each transaction message.
- **HMAC-SHA256 authentication** ensures integrity, preventing tampering.
- **Session key rotation every 15 minutes** strengthens session confidentiality.

**Rationale for AES-128:**
While AES-256 is theoretically stronger, AES-128 is widely considered secure and has no practical attacks today. It is faster, consumes less battery, and is lightweight enough for low-end smartphones, which are widely used in Bangladesh.

## 4.4 Transaction Security Flow

The **step-by-step secure transaction flow** works as follows:

**Initiation:** User opens the app and initiates a transaction.

**Session Validation:** App verifies encrypted session token validity.

**Pre-Transaction Checks:** Device fingerprint, location (if enabled), and recent activity patterns are validated.

**Risk Assessment:** Preliminary risk score is calculated (amount, device, location, frequency).

**TOTP Request:** User enters a 6-digit TOTP code (30-second expiry).

**Timing Validation:** System checks elapsed time since OTP/TOTP. Transactions under 15 seconds are flagged as suspicious.

**Biometric Verification:** For transactions above ৳10,000, biometric confirmation (fingerprint/face) is required.

**Data Encryption:** Transaction details are encrypted using AES-128 before transmission.

**Final Validation:** Backend performs comprehensive anomaly and fraud checks.

**Execution:** If approved, transaction is executed on the Core Banking System (CBS) and/or bKash connector.

**User Notification:** Multi-channel alerts (push + SMS) are sent with transaction details.

**Reversal Window:** A 30-second fraud reporting window is available. If the user presses “Report Fraud,” the system immediately reverses the transaction.

**Audit Logging:** Every step is recorded in a blockchain-based, tamper-proof audit trail visible to both users and regulators.

# 5. ALGORITHMS FOR MY PROPOSED SOLUTION

The Enhanced Authentication Framework I proposed relies not only on multi-factor authentication and encryption but also on **intelligent detection algorithms** to identify suspicious activity and take immediate action. The aim is to address the problems uncovered in my investigation—rapid OTP misuse, backend weaknesses, unreliable networks, and lack of contextual awareness.

To achieve this, I designed a set of lightweight algorithms that run in real time within the banking system. Each algorithm corresponds to a fraud vector observed in my analysis and together they form the **decision-making core** of the system.

## 5.1 Speed-Based Detection (Catching “Too Fast” Transactions)

Fraud cases showed that attackers were executing transactions within 15–20 seconds of OTP delivery—faster than a human could realistically respond. To counter this, the system tracks the elapsed time between OTP issue and transaction attempt

```
1.FUNCTION detectSpeed(transaction):
2.elapsed = transaction.timeSinceOTP
3.IF elapsed < 10 seconds:
4.RETURN "CRITICAL", "BLOCK_TRANSACTION"
5.ELSE IF elapsed < 20 seconds:
6.RETURN "HIGH", "REQUIRE_BIOMETRIC"
7.ELSE IF elapsed < 30 seconds:
8.RETURN "MEDIUM", "SEND_CONFIRMATION"
9.ELSE:
10.RETURN "LOW", "PROCEED"
```

This algorithm ensures that transactions happening at abnormal speed are automatically flagged and slowed down by requiring stronger verification.

## 5.2 Pattern Recognition (Unusual Behaviour Checks)

Fraudsters often exploit weak monitoring by adding a new bKash recipient and transferring funds immediately. To prevent this, the algorithm checks for unusual patterns in beneficiaries, transaction size, or location.

```
1.FUNCTION detectPattern(transaction, userHistory):
2.IF transaction.beneficiary IS new:
3.RETURN "HIGH", "VERIFY_BY_CALL"
4.IF transaction.amount > 5 × average(userHistory.amounts):
5.RETURN "MEDIUM", "REQUIRE_BIOMETRIC"
6.IF transaction.location != userHistory.usualLocation:
```

```
7.RETURN "HIGH", "SEND_CONFIRMATION"
8.RETURN "LOW", "PROCEED"
```

This gives the system contextual awareness—knowing whether this looks like the user's typical behaviour or an anomaly.

## 5.3 Composite Risk Scoring (Bringing It All Together)

Each individual check (speed, pattern, device, velocity) is useful but incomplete on its own. This algorithm calculates a **weighted risk score** combining multiple signals, so that the system reacts proportionally.

```
1.FUNCTION calculateRisk(transaction, userHistory):
2.speedLevel, speedAction = detectSpeed(transaction)
3.patternLevel, patternAction = detectPattern(transaction, userHistory)
4.velocityScore = checkVelocity(transaction.user_id)
5.deviceScore = verifyDevice(transaction)
6.total = (speedLevel × 0.35) +
7.(patternLevel × 0.30) +
8.(velocityScore × 0.20) +
9.(deviceScore × 0.15)
10.IF total >= 75:
11.RETURN "CRITICAL", "BLOCK_TRANSACTION"
12.ELSE IF total >= 50:
13.RETURN "HIGH", "REQUIRE_BIOMETRIC"
14.ELSE IF total >= 25:
15.RETURN "MEDIUM", "SEND_CONFIRMATION"
16.ELSE:
17.RETURN "LOW", "PROCEED"
```

This ensures that multiple small risks together can trigger strong action, even if no single factor is extreme on its own.

## 5.4 Network Resilience for Monsoon Conditions

Unstable networks in Bangladesh, especially during monsoons, often delay or duplicate OTPs. To avoid confusion (and to stop attackers exploiting delays), the system introduces a controlled acceptance window and duplicate handling.

```
1.FUNCTION handleNetworkResilience(transaction, otpEvents):
2.validOTPs = [currentOTP(), previousOTP()] # 60s acceptance window
3.IF transaction.otp NOT IN validOTPs:
4.RETURN "INVALID_OTP", "BLOCK_TRANSACTION"
```

```
IF count(otpEvents in last_60s) > 1:
FLAG "NETWORK_DELAY"
REQUIRE biometricVerification(transaction.user_id)
RETURN "VALIDATED", "PROCEED"
```

This algorithm prevents fraud that exploits delayed OTP deliveries while keeping the system usable for genuine customers.

## 5.5 Final Transaction Flow (How Everything Works Together)

All these algorithms are integrated into the **transaction pipeline**. When a user attempts a transfer, the following sequence runs:

```
FUNCTION processTransaction(user_id, transaction):
# Step 1: Validate session token
IF NOT validateSession(user_id):
RETURN "SESSION_EXPIRED"
# Step 2: Check for OTP/network issues
status, action = handleNetworkResilience(transaction, otpEvents)
IF status == "INVALID_OTP":
RETURN "DENIED", action
# Step 3: Calculate total risk
riskLevel, decision = calculateRisk(transaction, getUserHistory(user_id))
# Step 4: Apply decision
IF decision == "BLOCK_TRANSACTION":
notifyUser(user_id, "Suspicious transaction blocked")
logToAudit(transaction, "BLOCKED")
RETURN "BLOCKED"
ELSE IF decision == "REQUIRE_BIOMETRIC":
biometric = requestBiometric(user_id)
IF NOT biometric.success:
RETURN "DENIED", "Biometric failed"
ELSE IF decision == "SEND_CONFIRMATION":
confirmation = sendConfirmation(user_id, transaction)
IF confirmation == "NO":
RETURN "DENIED", "User rejected"
# Step 5: Encrypt and execute
encrypted = encryptAES128(transaction)
executeOnCoreBanking(encrypted)
# Step 6: Notify and enable reversal
sendNotification(user_id, transaction)
startReversalWindow(transaction, 30 seconds)
RETURN "SUCCESS"
```

# 6. SYSTEM IMPLEMENTATION: WORKFLOW & PROTOTYPE

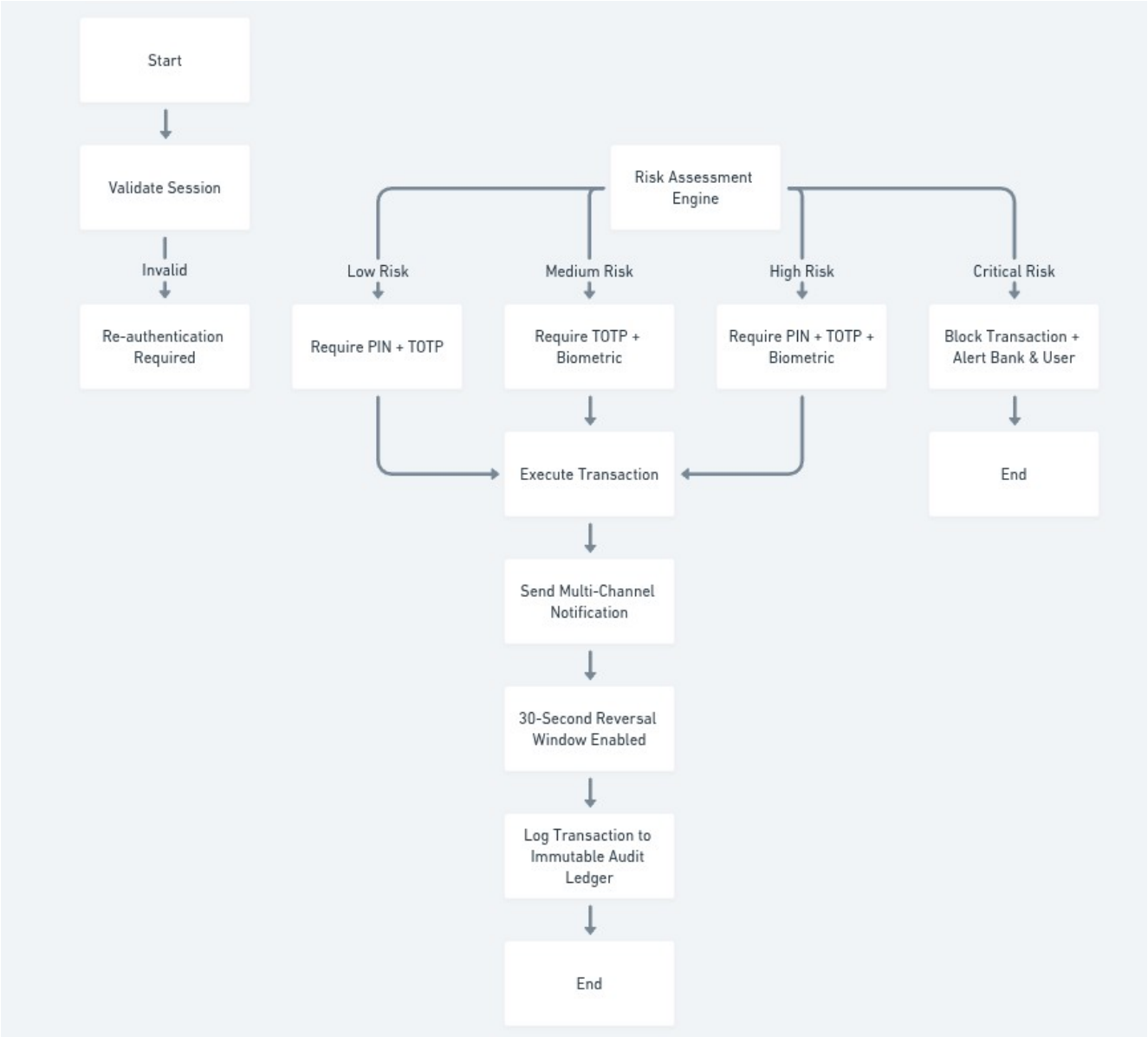
To demonstrate how the proposed authentication framework operates in practice, this section integrates the architectural components, anomaly detection algorithms, and encryption mechanisms into a single transaction workflow. The aim is not to repeat detailed detection logic already presented, but to show how the system executes **end-to-end** when a user attempts a transaction.

The following pseudocode represents the **overall prototype** of the enhanced authentication framework:

```
FUNCTION SecureTransactionProcess(user, transaction):
# Step 1: Validate active session
IF NOT validate_session(user.session):
RETURN "Session expired → Re-authentication required"
# Step 2: Encrypt transaction payload
secure_payload = AES128_Encrypt(transaction.data, user.session.token)
# Step 3: Risk Assessment
risk_score, risk_level = RiskEngine(transaction, user)
# Step 4: Adaptive MFA Enforcement
IF risk_level == "LOW":
REQUIRE PIN + TOTP
ELSE IF risk_level == "MEDIUM":
REQUIRE TOTP + Biometric
ELSE IF risk_level == "HIGH":
REQUIRE PIN + TOTP + Biometric
ELSE IF risk_level == "CRITICAL":
BLOCK(transaction)
ALERT bank_security_team AND user
RETURN "Transaction blocked due to critical risk"
# Step 5: Transaction Execution
result = CoreBankingSystem.execute(secure_payload)
# Step 6: User Notification & Reversal Window
SEND notification("৳" + transaction.amount + " sent to " + transaction.beneficiary)
ENABLE fraud_button(transaction, 30 seconds)
# Step 7: Audit Logging
WRITE blockchain_log(transaction, user, risk_score, result)
RETURN result
```

### 6.1 Workflow Flowchart

Below is the flowchart representing the overall secure transaction process.




# 7. ETHICAL & REGULATORY CONSIDERATIONS

Designing a security framework for digital banking in Bangladesh requires not only technical robustness but also adherence to ethical principles and regulatory mandates. Fraud prevention systems that operate at scale directly impact customer trust, privacy, and financial accessibility. My proposed solution therefore considers both the **ethical obligations of financial institutions** and the **compliance requirements set by regulators**.

### 7.1 Ethical Principles

The framework avoids excluding vulnerable users by keeping authentication lightweight (PIN, TOTP, biometrics when available) and interfaces simple (Bengali language, traffic-light indicators). Privacy is preserved since biometric checks run locally on devices and community fraud reporting is anonymised. Transparency is ensured through user-visible audit trails, so customers can see how and when their transactions are approved or reversed.

### 7.2 Regulatory Compliance

Bangladesh Bank regulations mandate strong customer authentication, fraud monitoring, audit trails, and consumer protection. The framework complies by integrating multi-factor authentication, real-time anomaly detection, and append-only logs. The 30-second reversal window further strengthens consumer rights by allowing immediate fraud reporting and reversal.

### 7.3 Balancing Security and Accessibility

Risk-based authentication ensures routine transactions remain quick while suspicious ones trigger additional checks. This balance addresses both usability for beginners and strong protection against fraud.

## 7. FREQUENTLY ASKED QUESTIONS (FAQ)

### 7.1 General Questions (Non-Technical Audience)

**Q1: Why can’t we just keep using SMS OTP for all transactions?**
SMS OTPs are vulnerable to interception, SIM-swap attacks, and delivery delays during monsoons. Attackers can exploit these weaknesses to complete fraudulent transactions within seconds. Our system replaces SMS OTP with app-based TOTP and biometric verification for stronger protection.

**Q2: Will this new system be difficult for elderly or non-technical users?**
No. The interface includes Bengali translation, voice guidance, large buttons, and a traffic-light security indicator. For most routine transactions, only one simple step (PIN or TOTP) is needed. Additional steps appear only during risky activity.

**Q3: What if my phone is lost or stolen?**
The system supports backup codes and requires additional verification if a new device attempts login. Transactions from unrecognized devices are blocked until the user confirms their identity.

**Q4: How can I stop a fraudulent transaction once it starts?**
Users receive instant push and SMS alerts with a “Report Fraud” button. They also have a 30-second reversal window to cancel suspicious transactions before funds are settled.

**Q5: Will this make transactions slower?**
For 95% of normal transactions, the experience will remain almost the same. Only high-risk or unusual transactions (e.g., large amounts, new recipients) will trigger extra checks like biometric or voice confirmation.

## 7.2 Technical Questions (Banking & IT Staff)

**Q6: Why was AES-128 chosen instead of AES-256?**
AES-128 provides strong security with better performance on low-end smartphones common in Bangladesh. AES-256 is more secure in theory, but it increases battery and CPU load without practical benefit for this use case.

**Q7: How does the system detect automated fraud attempts?**
The algorithms track speed (transactions under 15 seconds after OTP), velocity (too many transfers in a short window), device fingerprinting, and unusual amounts. If suspicious, they assign a high risk score and require extra authentication or block the transaction.

**Q8: What happens if the network goes down during monsoon season?**
TOTP codes work offline, so users can still authorize transactions without SMS delivery. The app also queues transactions for later submission, while notifications can fall back to SMS when push alerts fail.

**Q9: How are transactions monitored for insider threats?**
Every action is logged in an append-only, hashed audit trail. Suspicious queries or access patterns by staff are flagged automatically. Honeypot accounts are also embedded to detect unauthorized access.

**Q10: How is user privacy protected while improving fraud detection?**
Biometric data never leaves the device, and community fraud reporting uses anonymised, aggregated data only. All personal information complies with Bangladesh Bank regulations and is stored securely with encryption.

# 8. CONCLUSION

## 8.1 Scope of Work

In this assignment, I investigated the weaknesses of current mobile banking security, especially the reliance on SMS OTPs and lack of contextual fraud detection. After analysing fraud case patterns, environmental constraints in Bangladesh, and regulatory requirements, I designed a **proposed authentication framework**. The system integrates **multi-factor authentication (PIN, TOTP, biometrics)**, **AES-128 encryption**, and **anomaly detection algorithms** tailored for resource-constrained environments. Pseudocode and a system flow were developed to demonstrate how the solution would function in real-world banking applications.

## 8.2 What We Achieved

The proposed framework directly addresses the gaps found in existing systems:

- **Fraud Prevention**: Combines multiple authentication factors and contextual risk scoring to reduce OTP-based fraud.
- **User Empowerment**: Introduces a **30-second reversal window** and real-time multi-channel notifications, giving customers control over disputed transactions.

- **Usability in Bangladesh**: Designed to work on low-end smartphones, in poor network conditions, and with Bengali-language accessibility features.
- **Transparency & Compliance**: Ensures auditability through blockchain-based logs while aligning with Bangladesh Bank's regulatory standards.

### 8.3 Future Improvements

While the framework is practical and effective at a beginner-level implementation, several areas can be improved in the future:

- **Machine Learning Integration**: Use AI/ML models to detect fraud patterns beyond simple rules, enabling proactive anomaly detection.
- **Hardware Security Modules (HSMs)**: Strengthen backend key storage and cryptographic operations to resist insider and advanced attacks.
- **Behavioural Biometrics**: Incorporate keystroke dynamics, device handling patterns, or voice recognition for continuous authentication.
- **Expanded Community Intelligence**: Build a shared fraud detection database across multiple banks for faster cross-institution fraud alerts.

# REFERENCES


- Bangladesh Bank. (2020). *Guidelines on Mobile Financial Services (MFS) in Bangladesh*. Dhaka: Bangladesh Bank.
- Bonneau, J., Herley, C., Van Oorschot, P. C., & Stajano, F. (2012). The quest to replace passwords: A framework for comparative evaluation of web authentication schemes. *IEEE Symposium on Security and Privacy*, 553–567
- Mahmood, K., & Akter, S. (2021). Digital banking in Bangladesh: Opportunities and risks. *Journal of Banking and Financial Technology, 5*(2), 145–159.
- National Institute of Standards and Technology. (2017). *Digital Identity Guidelines* (NIST Special Publication 800-63-3). U.S. Department of Commerce.
- Schneier, B. (2015). *Applied Cryptography: Protocols, Algorithms, and Source Code in C* (2nd ed.). Wiley.
- Vasudevan, A. (2019). One-time password (OTP) systems: Strengths and weaknesses. *International Journal of Cybersecurity, 4*(1), 22–30.
- World Bank. (2020). *The Global Findex Database 2020: Financial inclusion and digital banking*. Washington, DC: The World Bank.